

SIMATS ENGINEERING

ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT3)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Report Analysis Questions

1. A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system. **(20 Marks)**

A) Analysis of Nmap Scan Report

An Nmap scan of the target **192.168.1.10** identified the following open ports:

- **Port 22 – SSH**
- **Port 80 – HTTP**
- **Port 3306 – MySQL**
- Operating system and service versions were also detected.

Security Risks of the Identified Services

a) SSH (Port 22)

- SSH provides secure remote administration.
- Risks:
 - Weak passwords can be cracked through brute-force attacks.
 - Outdated SSH versions may contain known vulnerabilities.
 - Unauthorized access may allow attackers to control the server.

Possible Exploitation

- Password guessing or brute-force attacks.
- Exploiting software vulnerabilities in outdated SSH services.
- Using stolen credentials to gain remote access.

Security Measures

- Use strong, unique passwords.
- Enable public key authentication.
- Disable root login via SSH.

- Limit SSH access using firewalls or IP whitelisting.
- Enable multi-factor authentication (MFA).
- Keep SSH software updated.

b) HTTP (Port 80)

- HTTP hosts web applications and websites.
- Risks:
 - Data is transmitted without encryption.
 - Web application vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), and File Inclusion.
 - Server version disclosure helps attackers identify known vulnerabilities.

Possible Exploitation

- Injecting malicious SQL queries.
- Stealing user sessions using XSS.
- Exploiting vulnerable web server software.
- Directory traversal attacks.

Security Measures

- Redirect HTTP traffic to HTTPS.
- Use TLS/SSL certificates.
- Regularly update the web server.
- Deploy a Web Application Firewall (WAF).
- Perform regular vulnerability assessments.

c) MySQL (Port 3306)

- MySQL stores application databases.
- Risks:
 - Database exposed directly to the network.
 - Weak database passwords.
 - Default accounts left enabled.
 - Old database versions with known vulnerabilities.

Possible Exploitation

- Unauthorized database login.
- Theft or modification of sensitive data.
- Privilege escalation.
- Remote code execution through vulnerable database software.

Security Measures

- Restrict MySQL access to trusted hosts only.
- Disable remote database access when unnecessary.
- Use strong authentication.
- Remove default accounts.
- Apply security patches regularly.
- Encrypt sensitive database information.

Operating System and Service Version Detection Risks

Nmap's OS and version detection provides attackers with:

- Operating system details.
- Exact service versions.

- Information about known vulnerabilities.

Possible Exploitation

Attackers compare detected versions with public vulnerability databases and exploit unpatched software.

Security Measures

- Keep systems fully patched.
- Minimize unnecessary services.
- Hide service banners where possible.
- Use intrusion detection and prevention systems.

Conclusion

The scan reveals valuable information that attackers could use to compromise the target. Proper patch management, secure configurations, access controls, encryption, and continuous monitoring significantly reduce the attack surface.

2. A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.(20 Mark).

A)Analysis of GoPhish Phishing Awareness Report (20 Marks)

Report Summary

- **40%** of employees clicked the phishing link.
- **20%** entered their login credentials.
- Several employees downloaded a malicious attachment.

Security Weaknesses Identified

a) High Click Rate (40%)

This indicates that many employees:

- Failed to identify phishing emails.
- Trusted suspicious links.
- Did not verify the sender.

Security Risk

- Malware infection.
- Credential theft.
- Account compromise.

b) Credential Submission (20%)

Employees entered usernames and passwords into fake websites.

Security Risk

- Unauthorized system access.
- Identity theft.
- Data breaches.
- Business Email Compromise (BEC).

c) Downloading Malicious Attachments

Some employees opened infected files.

Security Risk

- Ransomware infection.
- Trojan installation.
- Remote Access Trojans (RATs).
- Spyware deployment.

User Awareness Recommendations

1. Regular Security Awareness Training

Employees should learn:

- How to recognize phishing emails.
- How to identify fake websites.
- Safe email practices.
- Password security.

2. Simulated Phishing Campaigns

Conduct periodic phishing simulations to:

- Measure employee awareness.
- Provide immediate feedback.
- Improve recognition of phishing attempts.

3. Security Awareness Posters and Newsletters

Provide:

- Monthly security tips.
- Examples of phishing emails.
- Updates on emerging threats.

4. Incident Reporting Training

Employees should know:

- How to report suspicious emails.
- Whom to contact.
- The importance of prompt reporting.

Email Security Controls

a) Spam Filtering

Deploy advanced email filtering to detect phishing emails.

b) SPF, DKIM, and DMARC

These email authentication mechanisms help prevent email spoofing.

c) Attachment Scanning

Automatically scan attachments using antivirus and sandbox technologies.

d) URL Filtering

Block access to malicious websites.

e) Multi-Factor Authentication (MFA)

Even if passwords are stolen, attackers cannot easily access accounts.

Organizational Policies

1. Acceptable Use Policy

Employees should follow safe email usage guidelines.

2. Password Policy

- Strong passwords.
- Password managers.
- Regular password updates where appropriate.

3. Security Awareness Policy

Mandatory cybersecurity training for all employees.

4. Incident Response Policy

Clearly define reporting procedures for suspected phishing attacks.

5. Least Privilege Principle

Limit user permissions to reduce damage if an account is compromised.

Conclusion

The GoPhish report demonstrates significant user vulnerability to phishing attacks. Combining continuous security awareness training, strong email security controls, and well-defined organizational policies can substantially reduce the success of social engineering attacks.

3. A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure..(10 Marks)

Analysis of DNS Zone Transfer (AXFR) Report Using Dig (10 Marks)

The DNS assessment report shows that the DNS server allows **DNS Zone Transfer (AXFR)** to unauthorized users.

Security Implications

A successful zone transfer exposes:

- Internal hostnames.
- Mail servers.
- Subdomains.
- DNS records.
- Network structure.

This information enables attackers to map the organization's infrastructure without directly scanning the network.

How Attackers Can Exploit the Information

1. Network Reconnaissance

Attackers identify:

- Web servers.
- Database servers.
- Mail servers.
- Backup servers.

2. Target Selection

Attackers focus on:

- Public-facing systems.
- Older servers.
- Misconfigured services.

3. Phishing Attacks

Knowledge of mail servers and hostnames helps attackers create convincing phishing emails.

4. Vulnerability Scanning

Attackers scan exposed systems for known vulnerabilities based on the discovered DNS records.

5. Lateral Movement

If attackers compromise one exposed system, the DNS information helps them navigate the internal network.

Best Practices to Secure DNS Infrastructure

1. Restrict Zone Transfers

Allow AXFR only to authorized secondary DNS servers using IP-based access controls.

2. Disable Public Zone Transfers

Prevent unauthorized users from requesting DNS zone transfers.

3. Implement DNSSEC

Use DNS Security Extensions (DNSSEC) to protect DNS data integrity and authenticity.

4. Use Split DNS

Maintain separate internal and external DNS zones so sensitive internal records are not publicly exposed.

5. Regular DNS Audits

Review DNS records periodically and remove unnecessary or outdated entries.

6. Apply Security Updates

Keep DNS server software updated to protect against known vulnerabilities.

7. Monitor DNS Activity

Use logging and intrusion detection systems to identify unusual DNS queries or unauthorized AXFR attempts.

Conclusion

An unrestricted DNS Zone Transfer exposes valuable network information that attackers can use for reconnaissance and targeted attacks. Restricting AXFR, implementing DNSSEC, using split DNS, maintaining current software, and continuously monitoring DNS activity are essential best practices for protecting the organization's DNS infrastructure.

Code of Conduct:

I bB varun kumar (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines pecified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

B varun kumar

RUBRICS FOR CALCULATION

Report Analysis

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Report Analysis and Interpretation	25%	Accurately interprets the security report, identifies all key findings, and explains their significance with excellent technical understanding.	Correctly interprets most findings with minor omissions or inaccuracies.	Identifies only some findings and provides limited interpretation.	Unable to interpret the report or identify key findings.
Identification of Security Risks and Vulnerabilities	25%	Correctly identifies all security risks, vulnerabilities, and possible attack vectors with clear technical justification.	Identifies most risks and vulnerabilities with minor errors.	Identifies only a few risks with limited technical explanation.	Fails to identify major risks or vulnerabilities.
Application of Cybersecurity Concepts and Countermeasures	30%	Applies appropriate ethical hacking concepts and recommends comprehensive, practical, and technically sound countermeasures.	Recommends suitable countermeasures with minor technical gaps.	Provides limited or partially appropriate recommendations.	Recommendations are inappropriate, incomplete, or missing.
Technical Communication and Documentation	20%	Response is well-organized, technically accurate, clearly presented, and uses appropriate cybersecurity terminology throughout.	Response is organized and understandable with minor documentation or presentation issues.	Response lacks clarity, organization, or contains several technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.